

Google OAuth Scope Changes & CASA Cost

Scope Changes

Service	Scope	Before	After	Classification	Reason
Gmail	gmail.readonly	✓	✓	Restricted	AI reads incoming emails to summarize customer inquiries and draft replies
Gmail	gmail.modify	✓	✗	Restricted	Was intended for mark-as-read after AI processing, but feature was never implemented. Replaced by gmail.send which covers the actual sending use case
Gmail	gmail.labels	✓	✗	Sensitive	Was intended for AI-managed email labels (e.g. "AI Processed"), but feature was never implemented. Read/unread tracking is handled in our internal database
Gmail	gmail.send	✗	✓	Sensitive	AI sends drafted replies and user-composed emails on the user's behalf. Replaces gmail.modify — only sending is needed, no modification or label management
Drive	drive.file	✓	✓	Non-sensitive	User selects specific files via Google Picker API to import into AI knowledge base for document Q&A. Also allows AI agent to upload files to user's Drive
Drive	drive.readonly	✓	✗	Restricted	Was used to list all Drive files in a custom file browser. Replaced

					by Google Picker API — user now explicitly selects files, so app doesn't need access to all Drive files
Drive	drive.metadata.readonly	✓	✗	Restricted	Was used to display file names and types in custom file browser. Google Picker handles this natively, so no longer needed
Calendar	calendar.events	✓	✓	Sensitive	AI creates and updates calendar events when user schedules meetings via natural language (e.g. "Schedule a meeting with John next Tuesday")
Calendar	calendar.readonly	✓	✓	Sensitive	AI displays upcoming events in dashboard and checks user availability for scheduling
Calendar	calendar.events.readonly	✓	✓	Sensitive	AI reads existing events to provide context-aware suggestions and avoid scheduling conflicts
Meet	meetings.space.created	✓	✓	Sensitive	AI generates Google Meet links when scheduling meetings or when user requests a video call
Meet	meetings.space.readonly	✓	✓	Sensitive	AI reads Meet conference info to display active meetings in the dashboard

CASA Cost

	Before	After
--	--------	-------

Restricted scopes	4 (gmail.readonly, gmail.modify, drive.readonly, drive.metadata.readonly)	1 (gmail.readonly)
CASA required	Yes	Yes
Estimated cost	\$2,500 - \$5,000/year	\$2,500 - \$5,000/year
Assessment complexity	Higher (4 restricted scopes to review)	Lower (1 restricted scope to review)

One CASA certificate covers all restricted scopes. Cost is per assessment, not per scope.

Why Remove Restricted Scopes If CASA Cost Is The Same?

Since one CASA certificate covers all restricted scopes, keeping `gmail.modify` and `drive.readonly` would not increase the CASA cost. However, there are significant downsides to keeping unnecessary restricted scopes:

Con	Impact
Longer CASA assessment	Assessor must review data flows for each restricted scope. 4 restricted scopes = more documentation, more testing, more back-and-forth with assessor. Could add 2-4 weeks to the assessment timeline.
Higher risk of CASA rejection	Assessor may question why <code>gmail.modify</code> is requested when the app doesn't actually mark emails as read via the Gmail API. If the assessor flags it, Google may reject the entire verification.
Harder scope justification to Google	Google already flagged <code>gmail.modify</code> as too broad. Keeping it means arguing with Google about why it's needed — even though the feature isn't implemented. Google may reject the justification and delay verification further.
More data flows to document	Each restricted scope requires detailed documentation of how data is accessed, stored, transferred, and deleted in the CASA assessment. Fewer scopes = less documentation work.
Annual renewal complexity	CASA must be renewed every year. Each restricted scope must be re-justified and re-reviewed. Fewer scopes = simpler and faster annual renewal.
Broader user consent screen	More restricted scopes = scarier consent screen for users. Users see "Read, compose, and send emails" (<code>gmail.modify</code>) instead of just "Send email on your behalf" (<code>gmail.send</code>). This reduces user trust and conversion rates.
Unnecessary security risk	<code>gmail.modify</code> grants write access to emails (mark as read, modify labels). If the app doesn't use this, it's an unnecessary security exposure. Principle of least privilege.
Google may force removal later	Google is actively pushing apps toward narrower scopes. If they force removal later, you'll need to re-verify and re-do CASA. Better to do it now in one pass.